

Отчёт по лабораторной работе №3

Кибербезопасность предприятия

Абакумова Олеся,
Герра Гарсия Максимиано Антонио,
Канева Екатерина,
Клюкин Михаил,
Ланцова Яна,
НФИбд-02-22

Содержание

1	Цель работы	5
2	Выполнение лабораторной работы	6
2.1	Уязвимость 1. Слабый пароль пользователя.	6
2.2	Последствие уязвимости 1.	8
2.3	Уязвимость 2. XSS (CVE-2019-17427).	10
2.4	Последствие уязвимости 2.	14
2.5	Уязвимость 3. Blind SQL-инъекция. CVE-2019-18890.	16
3	Вывод	19

Список иллюстраций

2.1	Добавление инцидента по уязвимости 1	6
2.2	Пользователь со слабым паролем	7
2.3	Изменение пароля	7
2.4	Подтверждение изменения пароля пользователя dev1	8
2.5	Устранение уязвимости	8
2.6	Просмотр вредоносной задачи	9
2.7	Вредоносная задача	9
2.8	Удаление задачи	9
2.9	Удаление вредоносного файла	10
2.10	Последствие устранено	10
2.11	Описание уязвимости	11
2.12	Добавление инцидента по уязвимости 2	11
2.13	Просмотр главной страницы сайта	11
2.14	Файл с уязвимостью	12
2.15	Содержимое файла redcloth3.rb	12
2.16	Внесем изменения в файл	13
2.17	Перезапуск службы	13
2.18	Уязвимость 2 устранена	13
2.19	Вход в консоль администратора	14
2.20	Список пользователей Redmine	14
2.21	Удаление пользователя hacker	15
2.22	Пользователь hacker ликвидирован	15
2.23	Последствие уязвимости 2 устранено	15
2.24	Информация о CVE-2019-18890	16
2.25	Карточка инцидента для уязвимости 3	17
2.26	Файл query.rb	17
2.27	Внесение изменений в файл query.rb	18
2.28	Перезапуск службы веб-сервера	18
2.29	Все уязвимости и последствия устранены	18

Список таблиц

1 Цель работы

Защитить научно-техническую информацию предприятия от внутреннего нарушителя.

2 Выполнение лабораторной работы

2.1 Уязвимость 1. Слабый пароль пользователя.

Поскольку на файловом сервере установлен слабый пароль для входа в учетную запись, нарушитель может подобрать подходящий пароль со словарем.

Изучили уязвимость, добавили инцидент (рис. 2.1).

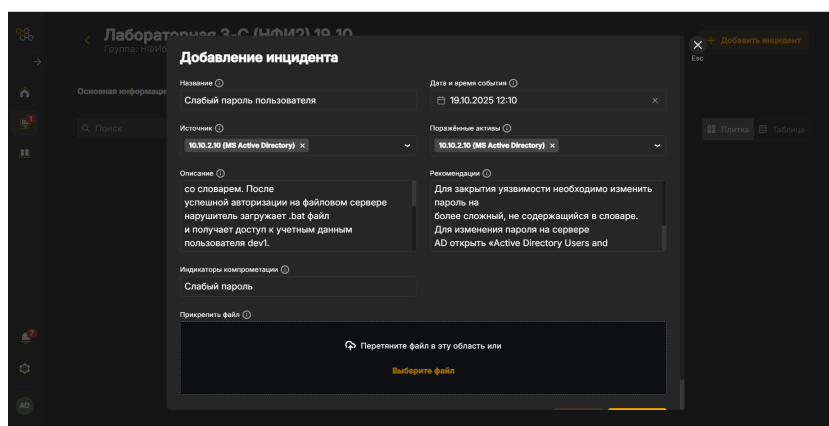


Рис. 2.1: Добавление инцидента по уязвимости 1

Для устранения уязвимости необходимо изменить простой пароль на сложный, который не содержится в словаре. Для этого на узле Active Directory перейдем в “Active Directory Users and Computers” и найдем пользователя dev1 (рис. 2.2).

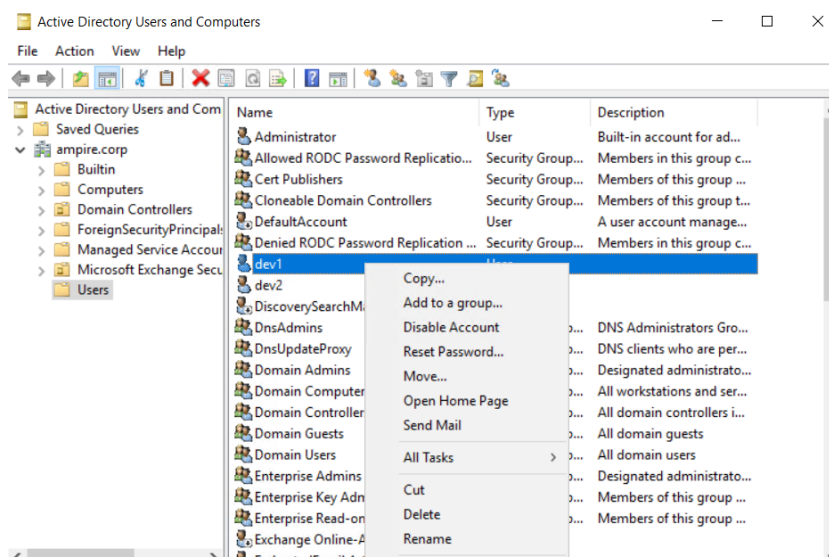


Рис. 2.2: Пользователь со слабым паролем

Установим пользователю новый пароль, который будет содержать числа, латинские буквы, а также специальные символы (рис. 2.3).

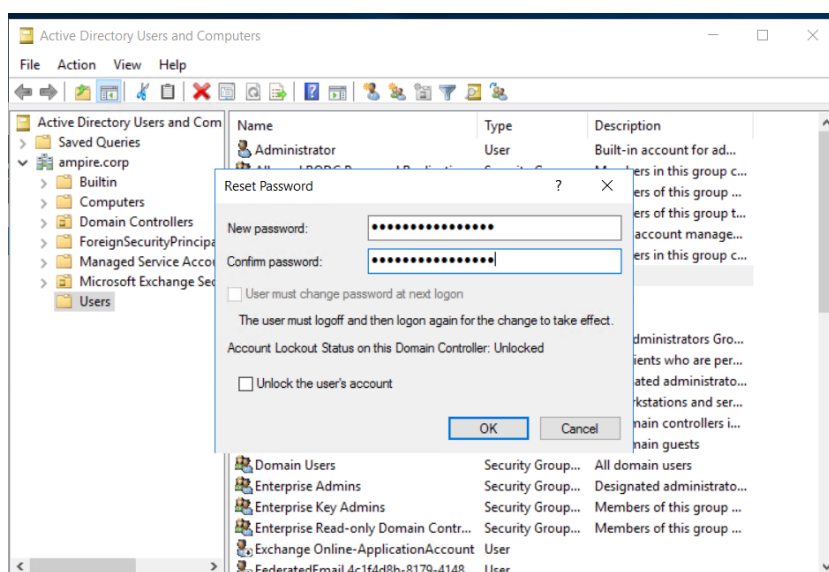


Рис. 2.3: Изменение пароля

Пароль успешно изменен, злоумышленник не сможет подобрать один из простых паролей (рис. 2.4).

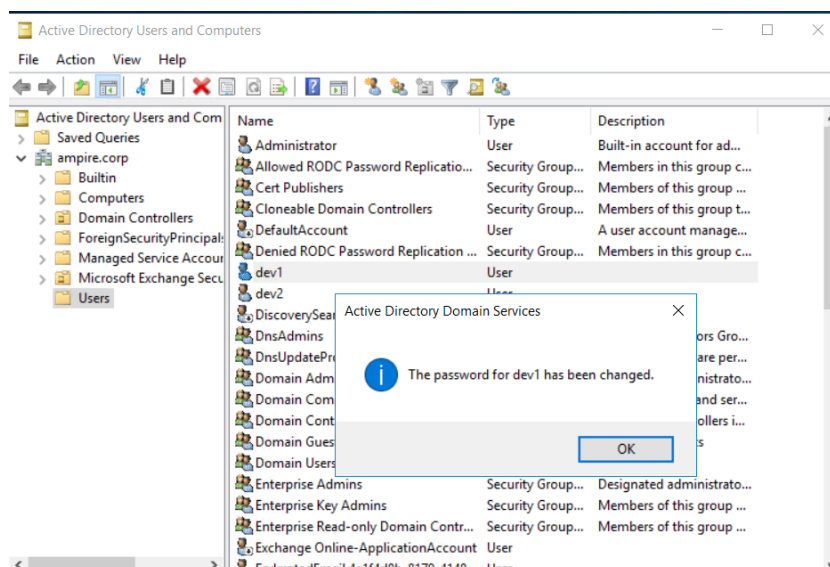


Рис. 2.4: Подтверждение изменения пароля пользователя dev1

После этого убедимся, что уязвимость была закрыта (рис. 2.5).

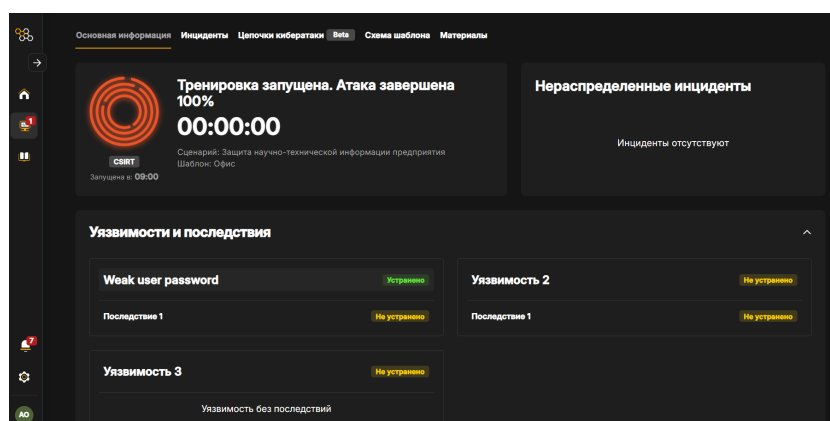


Рис. 2.5: Устранение уязвимости

2.2 Последствие уязвимости 1.

Перейдем на узел Developer 1 и устраним первое последствие. Для этого откроем планировщик задач и увидим задачу, которую создал нарушитель(рис. 2.6).

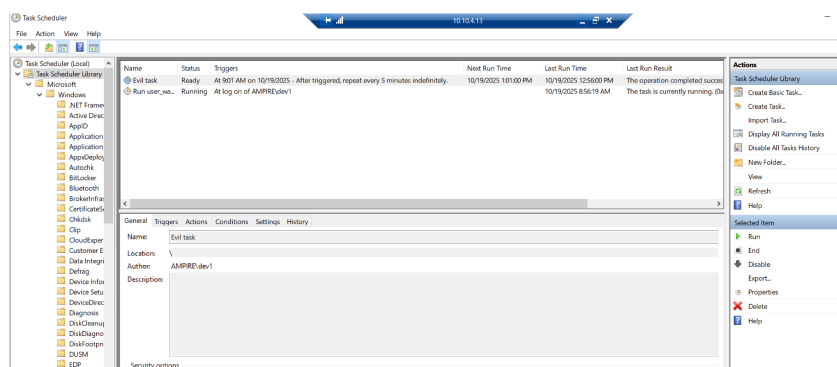


Рис. 2.6: Просмотр вредоносной задачи

В найденной задаче перейдем во вкладку “Actions” и увидим путь к исполняемому файлу злоумышленника (рис. 2.7).

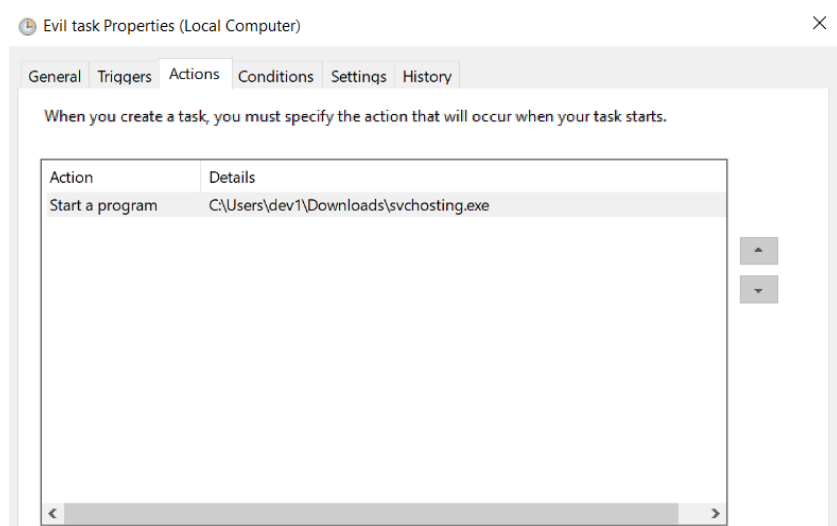


Рис. 2.7: Вредоносная задача

Удалим задачу “Evil task” из планировщика задач (рис. 2.8).

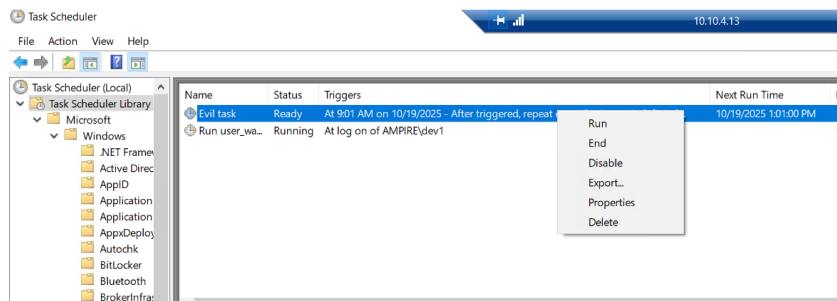


Рис. 2.8: Удаление задачи

Далее перейдем в директорию C:\Users\dev1\Downloads и удалим исполняемый файл, а также удалим его из корзины (рис. 2.9).

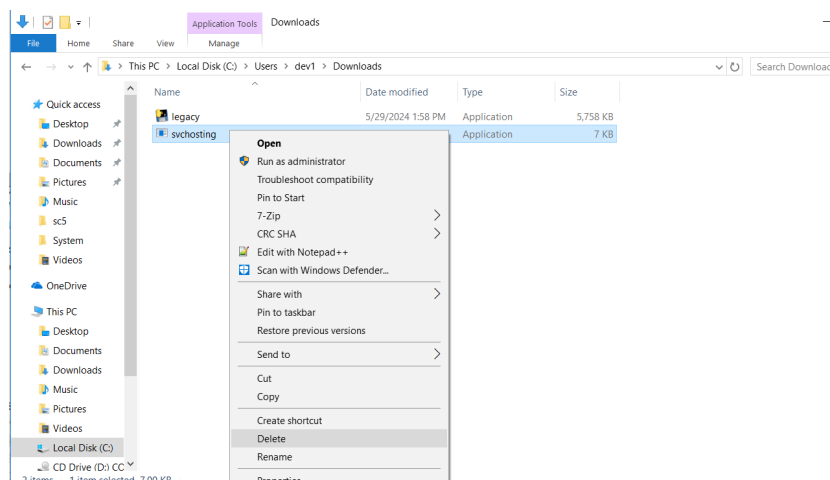


Рис. 2.9: Удаление вредоносного файла

После этого убедимся, что последствие для уязвимости было закрыто (рис. 2.10).

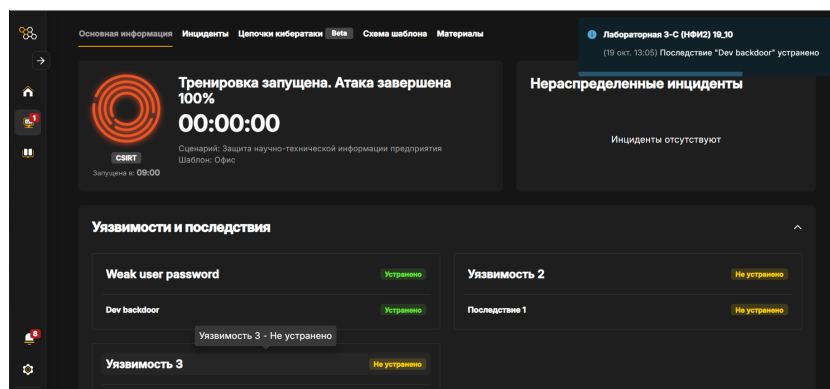


Рис. 2.10: Последствие устранено

2.3 Уязвимость 2. XSS (CVE-2019-17427).

Изучим информацию о CVE найденной уязвимости. Увидим, что критичность средняя. Злоумышленник, используя ошибку форматирования текста, может внедрить вредоносный код на веб-страницу Redmine (рис. 2.11):

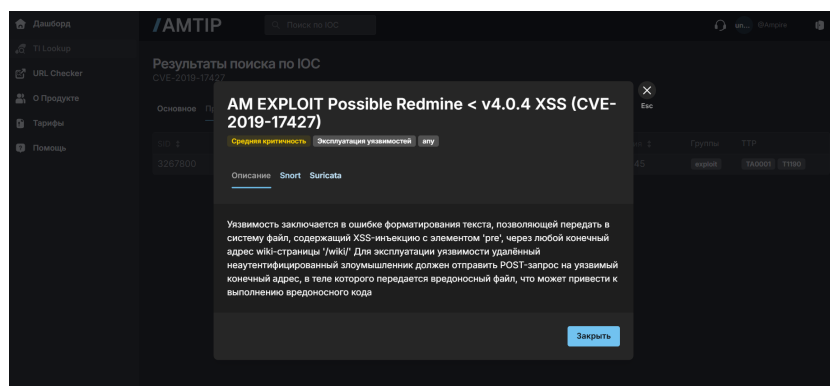


Рис. 2.11: Описание уязвимости

Изучили уязвимость, добавили инцидент (рис. 2.12).

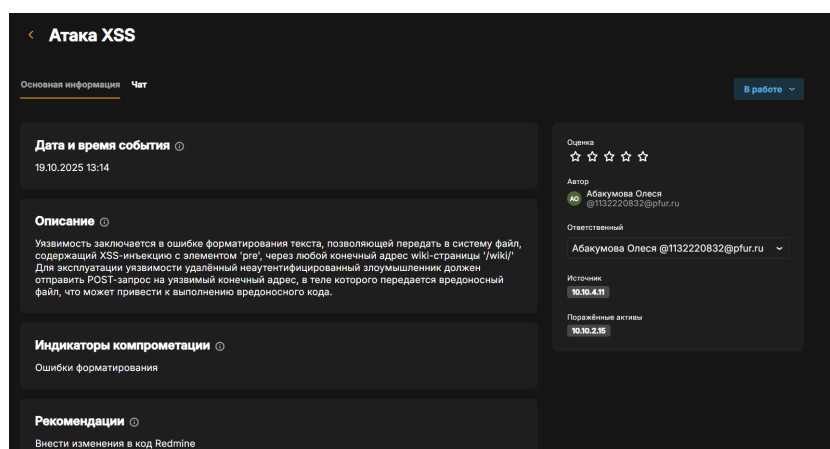


Рис. 2.12: Добавление инцидента по уязвимости 2

Внесем изменения в код Redmine, чтобы устранить уязвимость. Для начала изучим веб-страницу Redmine (рис. 2.13).

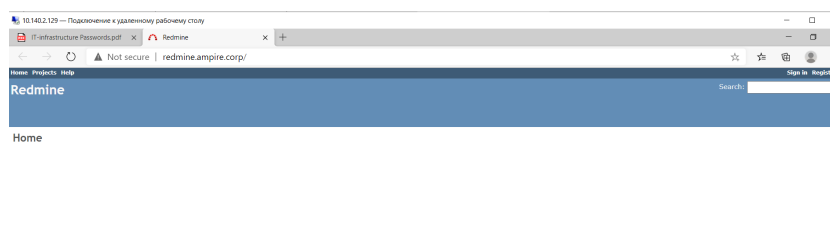


Рис. 2.13: Просмотр главной страницы сайта

Перейдем в каталог `/var/www/redmine/lib` и найдем файл `redcloth3.rb`, который необходимо исправить (рис. 2.14):

2.4 Последствие уязвимости 2.

Данная полезная нагрузка заключается в том, что нарушитель создает пользователя на портале Redmine. Пользователь, обладающий правами администратора, имеет неограниченный доступ к пользовательской базе.

Примечание: способ закрытия полезной нагрузки «Redmine User» не будет действовать до внесения изменений по закрытию уязвимости «Атака XSS»

Для обнаружения добавления нового привилегированного пользователя, достаточно зайти в консоль администратора Redmine по ссылке (<http://redmine.ampire.corp/login>), перейти в раздел «Administration» – «Users» и посмотреть список существующих пользователей (рис. 2.19):

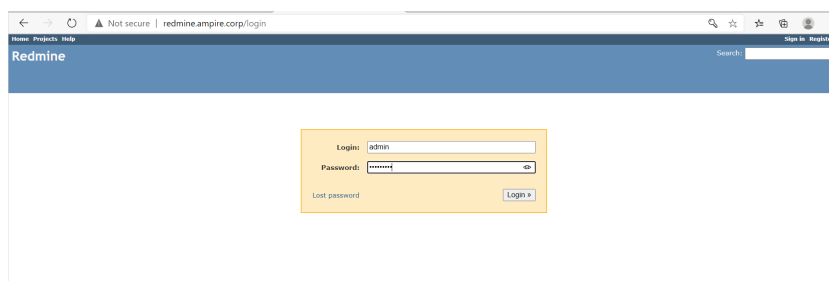


Рис. 2.19: Вход в консоль администратора

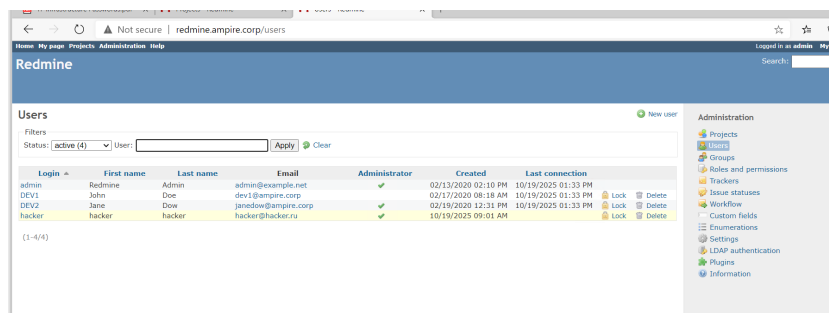


Рис. 2.20: Список пользователей Redmine

Для нейтрализации полезной нагрузки необходимо удалить созданного пользователя «hacker» через веб-интерфейс Redmine (рис. 2.21):

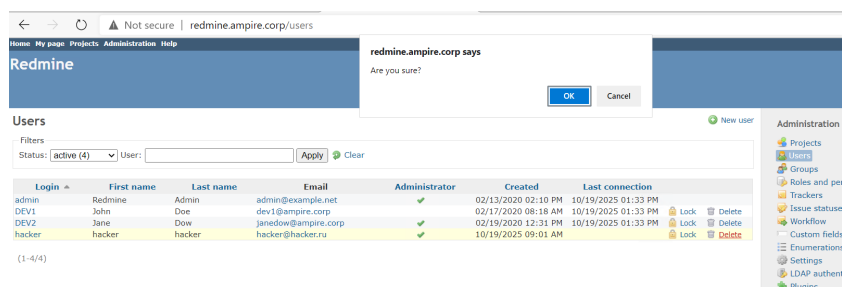


Рис. 2.21: Удаление пользователя hacker

Пользователь hacker успешно удален (рис. 2.22):

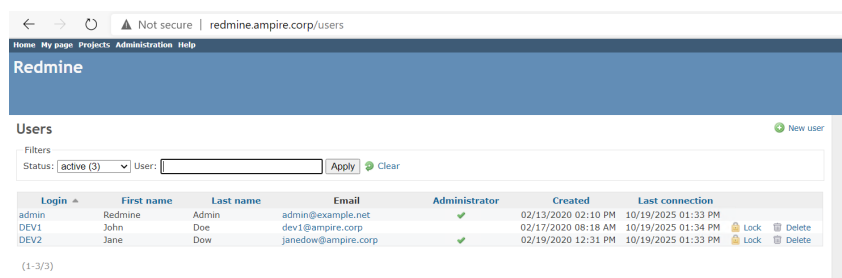


Рис. 2.22: Пользователь hacker ликвидирован

В результате удаления созданного пользователя «hacker» успешно нейтрализовано последствие Redmine User (рис. 2.23):

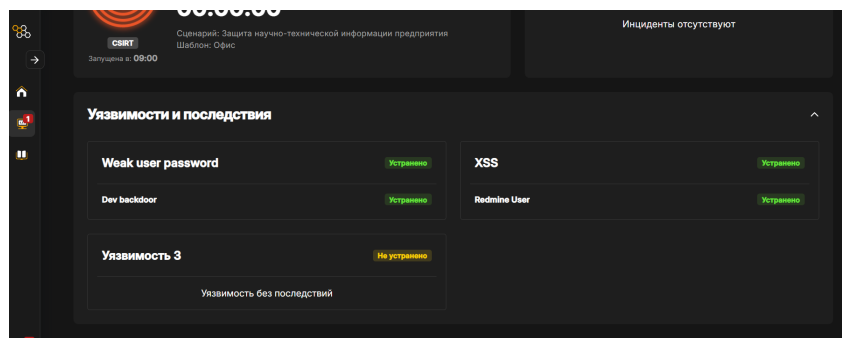


Рис. 2.23: Последствие уязвимости 2 устранено

2.5 Уязвимость 3. Blind SQL-инъекция.

CVE-2019-18890.

В Redmine до версии 3.2.9 и 3.3.x до версии 3.3.10 уязвимость позволяет пользователям Redmine получать доступ к защищенной информации с помощью сгенерированного объектного запроса. Уязвимость реализуется посимвольным перебором с замером времени ответа. В данном сценарии данная уязвимость используется для получения конфиденциальной информации из БД, минуя разграничение доступа Redmine. Время прихода пакета является индикатором: при запоздании пакета – символ подобран верно, иначе – перебор продолжается.

Посмотрим информацию об эксплуатируемой уязвимости CVE-2019-18890 (рис. 2.24):

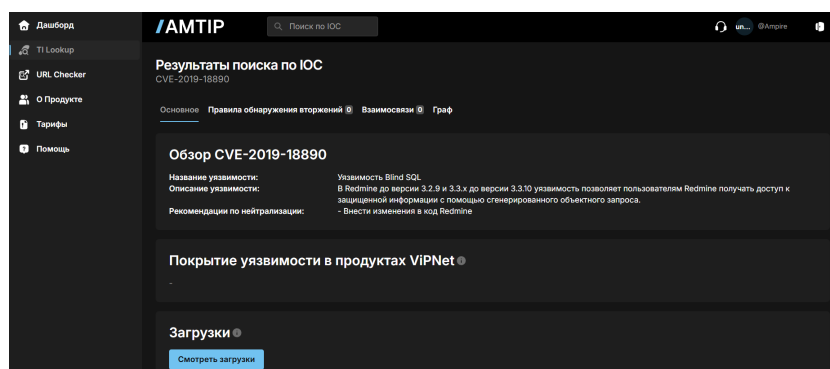


Рис. 2.24: Информация о CVE-2019-18890

Создаем карточку инцидента (рис. 2.25):

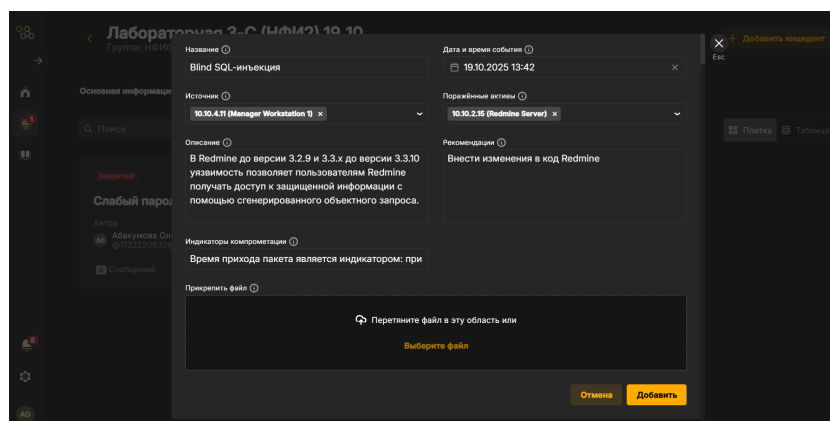


Рис. 2.25: Карточка инцидента для уязвимости 3

Решение: внести изменения в код Redmine. Исходя из адреса и запроса следует найти местоположение скрипта, где происходит обработка параметра `subproject_id`. В данном случае рассмотрен файл `query.rb`. Данный файл находится в директории `/var/www/redmine/app/models` (рис. 2.26):

```

/var/www/redmine/app/models/query.rb - user@10.10.2.15 - Editor - WinSCP
def grouped?
  !group_by_column.nil?
end

def group_by_column
  groupable_columns.detect {|c| c.groupable && c.name.to_s == group_by}
end

def group_by_statement
  group_by_column.try(:groupable)
end

def project_statement
  project_clauses = []
  if project && !project.descendants.active.empty?
    if has_filter?("subproject_id")
      case operator_for("subproject_id")
      when '='
        # include the selected subprojects
        ids = [project.id] + values_for("subproject_id").each(&:to_i)
        project_clauses << "(#{Project.table_name}.id IN (#{ids})" % ids.join(',')

```

Рис. 2.26: Файл `query.rb`

В данном случае следует добавить фильтрацию значений и закомментировать код (рис. 2.27):

```
10.140.2.129 — Подключение к удаленному рабочему столу
/var/www/redmine/app/models/query.rb - user@10.10.2.15 - Editor - WinSCP

def group_by_column
  groupable_columns.detect {|c| c.groupable == group_by}
end

def group_by_statement
  group_by_column.try(:groupable)
end

def project_statement
  project_clauses = []
  if project == project.descendants.active.empty?
    if has_filter?("subproject_id")
      case operator_for("subproject_id")
      when '='
        # Include the selected subprojects
        # ids = [project.id] + values_for("subproject_id").each(&:to_i)
        ids = [project.id] + values_for("subproject_id").map(&:to_i)
        project_clauses << "(Project.table_name).id IN (%s)" % ids.join(',')
      end
    end
  end
end
```

Рис. 2.27: Внесение изменений в файл query.rb

После внесения изменений необходимо перезапустить службу веб-сервера:
`sudo systemctl restart nginx.service`(рис. 2.28):

```
user@redmine: ~
Using username "user".
Last login: Sun Oct 19 13:28:24 2025 from 10.10.2.254
user@redmine:~$ sudo systemctl restart nginx.service
[sudo] password for user:
user@redmine:~$
```

Рис. 2.28: Перезапуск службы веб-сервера

Убедимся в том, что все уязвимости и последствия устранены (рис. 2.29):

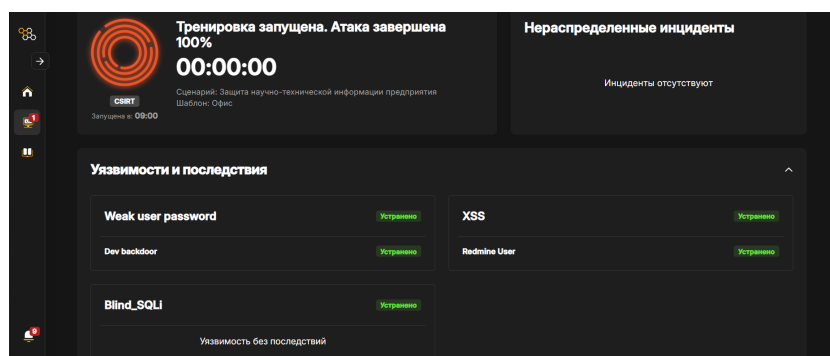


Рис. 2.29: Все уязвимости и последствия устранены

3 Вывод

Мы защитили научно-техническую информацию предприятия от внутреннего нарушителя и устранили последствия его атак.